GOM
GERENCIA DE OBRAS MINA

Seguridad ADP Casino Antes vs. estado actual

Comparación verificable del endurecimiento aplicado

ESTADO	RESULTADO CLAVE
MEJORA MATERIAL	**51 -> 10** **vulnerabilidades totales informadas en producción; 0 críticas actuales**

Fecha de evaluación

16 de octubre de 2026

Alcance

Backend Node.js, frontend React, dependencias, configuración HTTP y preparación operativa.

Documento preparado para revisión ejecutiva y técnica. No sustituye un pentest externo autorizado.

1. Objetivo

Comparar el estado observado antes del endurecimiento con el resultado obtenido después de aplicar controles compatibles con la funcionalidad existente de ADP Casino.

Este informe cubre los repositorios backend y frontend. No representa un pentest externo ni certifica que la aplicación esté lista para producción. No se modificaron datos de `BDADP_CASINO`.

2. Resumen ejecutivo

El cambio eliminó las vulnerabilidades críticas informadas por `npm audit`, dejó el frontend sin vulnerabilidades conocidas en dependencias de producción y agregó controles HTTP contra abuso, exposición de información y configuraciones inseguras.

La funcionalidad de Casino, Personas, sesiones, permisos y menú conserva sus rutas y contratos. Los riesgos pendientes más importantes son la rotación de secretos expuestos, las contraseñas legadas, la auditoría persistente y dependencias heredadas de Puppeteer.

3. Comparación antes y después

Área	Situación inicial	Estado actual	Resultado
Dependencias backend	37 vulnerabilidades: 2 críticas, 23 altas, 9 moderadas y 3 bajas	10 vulnerabilidades: 0 críticas, 8 altas y 2 moderadas	Se eliminaron todas las críticas y 27 observaciones
Dependencias frontend	14 vulnerabilidades: 11 altas, 1 moderada y 2 bajas	0 vulnerabilidades informadas	Remediado
Secretos en código actual	API key y credencial SQL literales en configuración PM2	Configuración basada en variables de entorno; búsqueda actual sin esos literales	Corregido en el árbol actual; falta rotación e historial
Imagen Docker	Copiaba `.env`, Git, documentos, pruebas, PDFs y outputs	`.dockerignore` excluye esos elementos	Corregido en código; falta construir y revisar la imagen
Usuario del contenedor	Proceso Node sin usuario explícito	Ejecución final como usuario `node`	Mejorado
Instalación Docker	`npm install` con resolución variable	`npm ci --omit=dev`	Reproducible y con menor superficie
Source maps frontend	Publicados en producción	Solo se generan fuera de producción	Corregido
Identificación del servidor	Express exponía `X-Powered-By`	Header deshabilitado	Corregido
Headers de seguridad	No había política transversal	CSP para API, HSTS en producción, `no-store`, `nosniff`, `DENY`, `no-referrer` y Permissions Policy	Implementado
Tamaño de solicitudes	Límites implícitos	JSON 256 KB; formularios 64 KB y 200 parámetros	Implementado
Fuerza bruta de login	Sin rate limit	20 solicitudes por IP cada 15 minutos, configurable	Implementado para una instancia Node
CORS rechazado	Error genérico de Express	HTTP 403 JSON sin detalles internos	Mejorado
Errores no controlados	Respuesta predeterminada de Express	Respuesta JSON homogénea sin stack para el cliente	Mejorado
Ruta técnica	`/backendDocker/test` era pública	Ruta retirada	Corregido
Pruebas backend	31 pruebas antes del endurecimiento actual	36 pruebas; las cinco nuevas validan controles HTTP	Mejorado
Verificación automatizada	No existía gate de seguridad	`security:smoke` y `security:gate`	Implementado

4. Controles que se conservaron

- La empresa continúa derivándose de la sesión mediante `req.context.empCod`.
- El navegador no puede sustituir `GECODEMP` o `EmpCod`.
- Las rutas de Casino siguen protegidas por permisos backend.
- Los pedidos, Personas y solicitudes mantienen filtros por empresa.
- El control operacional conserva además el filtro por Casino asociado al usuario.
- Los precios siguen obteniéndose desde SQL Server.
- La cookie sigue siendo `HttpOnly`, `SameSite=Lax` y `Secure` en producción.
- El token de sesión se genera aleatoriamente y SQL Server almacena solamente su hash.

5. Pruebas realizadas

Suite funcional y de reglas

```
node --test
```

Resultado: 36 pruebas correctas, 0 fallidas.

Smoke test de seguridad

```
npm run security:smoke
```

Resultado: 5 pruebas correctas:

1. headers defensivos y ausencia de `X-Powered-By`;
2. rechazo de origen CORS no autorizado;
3. rechazo de JSON superior a 256 KB;
4. HTTP 429 frente a intentos repetidos de login;
5. ausencia de la ruta técnica retirada.

Gate de seguridad

```
npm run security:gate
```

Resultado: correcto; no existen vulnerabilidades críticas informadas en dependencias de producción y el smoke test finaliza correctamente.

Frontend

- ESLint dirigido: correcto.
- Build Vite de producción: correcto.
- Source maps en `dist`: ninguno.
- `npm audit --omit=dev`: 0 vulnerabilidades.

Base de datos

`npm run verify:casino` confirmó acceso a la base, pero no terminó satisfactoriamente: el verificador esperaba 15 pedidos y encontró 23. Este cambio no creó ni eliminó pedidos. La fotografía esperada debe revisarse en una tarea independiente.

6. Riesgos residuales

Riesgo	Severidad estimada	Estado
Credenciales previamente publicadas en Git	Crítica hasta completar rotación	Pendiente externo
Copias del secreto en historial, clones o imágenes antiguas	Alta	Pendiente de procedimiento coordinado
Autenticación compatible con `USUARIOS.UsuClave`	Alta	Pendiente de corte de convivencia
Puppeteer y cadena heredada con 8 observaciones altas	Alta en inventario; exposición actual reducida porque sus rutas no están montadas	Pendiente de retirar o probar actualización
Dos observaciones moderadas transitivas de SQL Server	Moderada	Pendiente de actualización compatible del proveedor
Auditoría persistente de login y cambios de permisos	Alta	Pendiente
Rate limit en memoria	Moderada si existen varias instancias	Pendiente de almacén compartido
Validación de certificado y semántica de cifrado SQL	Alta para producción	Pendiente de prueba de infraestructura
MFA para administradores	Alta	Pendiente de definición e implementación

7. Conclusión

El estado actual es materialmente más seguro que el inicial y mantiene la funcionalidad aplicativa. La mejora es verificable y repetible, pero todavía no corresponde declarar la solución lista para producción ni aprobada por ethical hacking.